

Chapter 10 資訊安全管理

1. 資訊安全的三要素為何？

Answer：

機密性、完整性、與可用性。

2. 資訊安全政策之內容包含哪些項目？

Answer：資訊安全政策的內容可依資訊安全所規範之範疇與對象，做適度調整，主要包含下列項目：

資訊安全政策目的及範圍。

資訊安全的目標。

風險管理。

資訊安全管理的責任。

支援政策。

事件通報程序。

委外相關規定。

3. ISO/IEC 27001：2022 標準包含哪四個控管領域？並加以簡要說明。

Answer：新版也將原有的 14 個控管領域，整合為四大控管領域（組織控管、人員控管、實體控管、技術控管），以下針對四個控管領域做簡要說明。

組織控管 (organizational controls)：遵循已定義之預期規則，包含用戶、設備、軟體和系統的預期行為。例如，存取控制策略、BYOD 策略等。

人員控制 (people controls)：對相關人員提供知識、教育、技能或經驗，使他們能夠以安全的方式開展活動。例如，資訊安全觀念培訓、ISO/IEC 27001 稽核人員培訓等。

實體控制 (physical controls)：使用實體設備、裝置、或強化措施以提升安全。例如，閉路電視、警報系統、防護鎖等。

技術控制 (technological controls)：主要在資訊系統中，使用添加之軟體或硬體，達到提升安全之目標。例如，資料遺失預防設備、備份軟體、身分驗證、

存取控制軟體、防毒解毒軟體等。

Chapter 11 應用系統發展管理

1. 系統發展生命週期 (System Development Life Cycle, SDLC)，包含哪四個階段？簡要敘述之。

Answer：

軟體系統的發展是一個循環的過程，稱為系統發展生命週期 (System Development Life Cycle；SDLC)，如圖 11-1。基本上，系統發展生命週期包含四個階段：

- (1) 概念階段
- (2) 發展階段
- (3) 執行階段
- (4) 結束階段

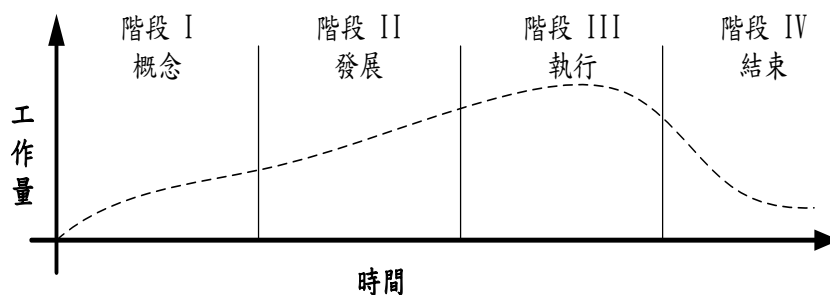


圖 11-1 系統發展的四個階段

2. 何謂軟體能力成熟度模式？

Answer：

軟體能力成熟度模式 (Software Capacity Maturity Model Integration) 是美國卡內基美隆大學 (Carnegie Mellon University) 的『軟體工程學院』(Software Engineering Institute) 所發展的一套具備組織性的系統工程和軟體工程整合模式。軟體能力成熟度模式可協助整合傳統上分開的企業組織功能，並訂立流程改善目標及優先順序，同時為欲實行最佳流程的公司提供指引及評估。軟體能力成熟度模式與軟體發展週期可以並存，它是提供軟體發展之整合

平台。

3. 建構管理之四項主要工作是什麼？

Answer：

在系統上線營運時，要保持系統的完整性，若任意改變系統的環境或參數時，會使系統不穩定、產生漏洞、缺失、錯誤，降低系統之安全性，造成系統安全弱點。因此需要完善的建構管理，以降低風險，提高系統安全性。

建構管理包含四項主要工作：

- (1) 建構識別 (Configuration Identification)
- (2) 建構控制 (Configuration Control)
- (3) 建構狀態記錄 (Configuration Status Accounting)
- (4) 建構審查 (Configuration Audit)

Chapter 12 營運持續計畫

1.營運持續計畫進行中的六個步驟為何？

Answer：

營運持續計畫 (Business Continuity Plan；BCP) 是企業營運持續管理的一部份，在開始建立營運持續計畫時，需要組成一個核心小組，成員需要涵蓋各部門人員，各成員需要充分了解建構營運持續計畫的使命與目標。在建構營運持續計畫進行中，概括可以分為六個步驟 (圖 12-2)：

- 計畫開始
- 營運衝擊分析
- 回復策略
- 計畫發展
- 計畫確認與測試
- 計畫維護與訓練

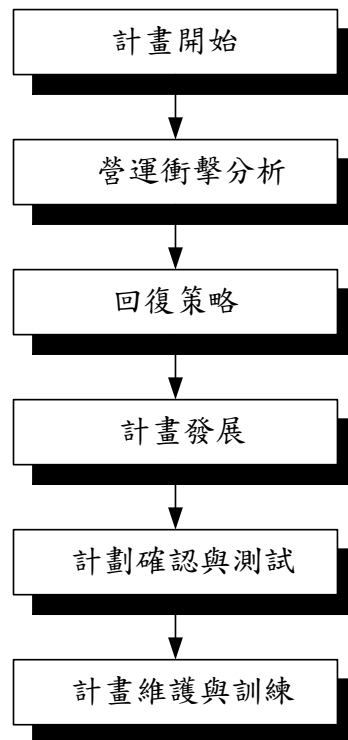


圖 12-2 營運持續計劃步驟

2. 營運恢復計畫之目的為何？

Answer：

當災害的威脅已經過去，在可確保人員的安全時，組織必須開始啟動營運恢復計畫。營運恢復計畫著重於當系統受到損害或混亂的衝擊時回復營運機能，混亂的衝擊可能是一小段的時間，但無法立即提供服務或正常功能，可能需要延誤相當的時間，所以需要把衝擊降到最低，讓資源作最有效的利用，以便儘速恢復正常營運。

Chapter 13 作業安全管理

1. 資訊資產可分為哪幾類？

Answer：

硬體資產

軟體資產

資料資產

支援設施

人員資產

2. 內部人員與外部人員造成資安事件威脅的比例為何？

Answer：

- 內部人員 80%
- 外部人員 5%

3. 在人員管理中，聘用人員時應注意事項為何？

Answer：

基於安全考量，人員在聘僱前，必須查核過去經歷與背景，以降低風險。聘用人員包含正式員工、約僱人員或第三方使用者。依照聘僱職務之需要進行過濾，查核學歷、證照與工作經歷，儘可能參考朋友、鄰居、同僚、部署或長官之意見，並透過舉辦測驗或面試，了解其能力與性向